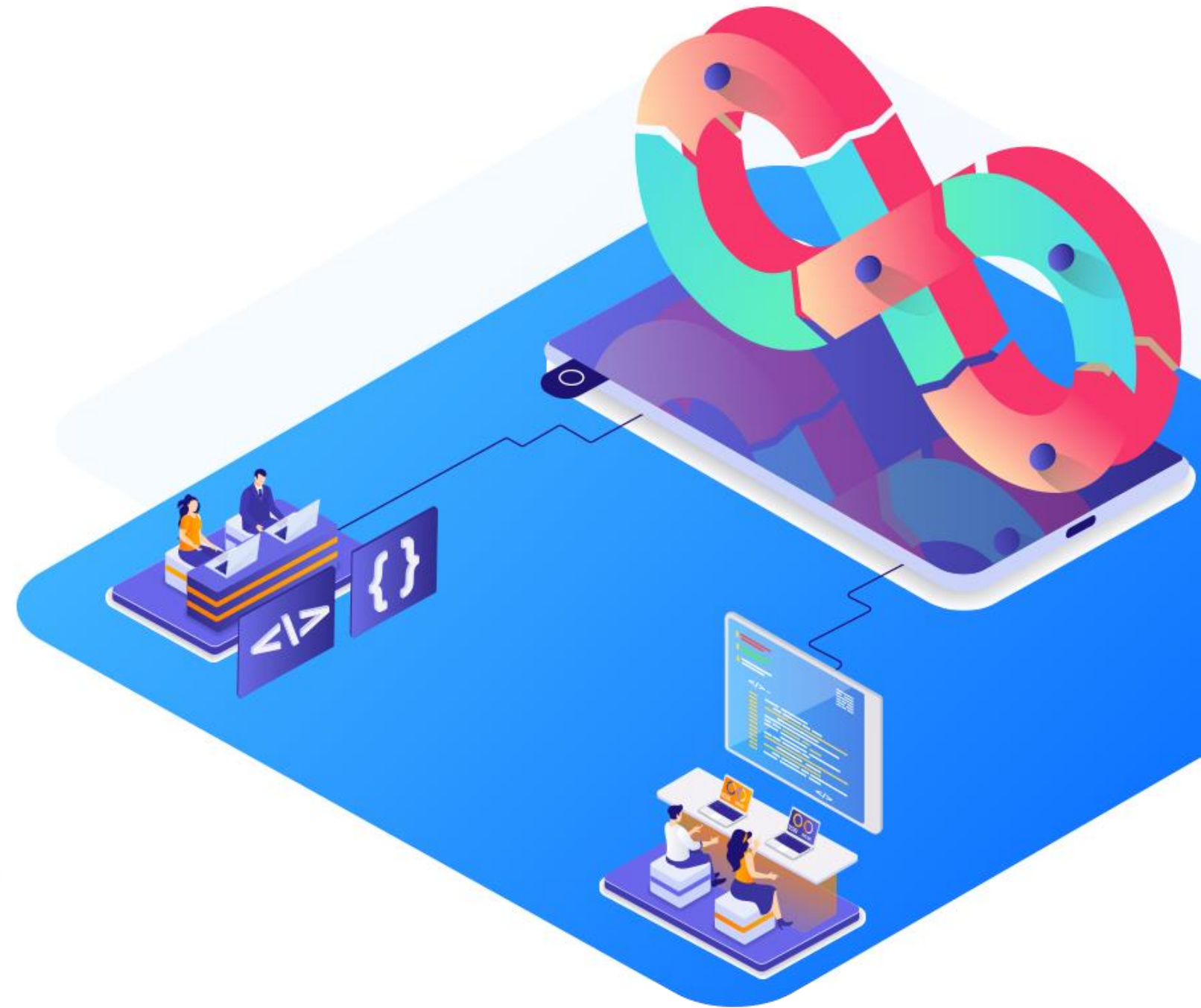


DevSecOps: Principles and AWS Cloud Security



Course-End Project





Securing CI/CD Pipeline with Automated Security Monitoring for Kubernetes-Hosted Applications

Objective

To create a CI/CD pipeline that automates the deployment of cloud-native applications to EKS and integrates automated security checks at every stage to ensure that vulnerabilities and compliance issues are detected early



Problem Statement and Motivation

Real-time scenario:

An e-commerce company, ShopPro Online, revamped its infrastructure by hosting microservices-based applications on Amazon EKS and integrated AWS Security Hub for continuous security monitoring. During deployment, Security Hub detected critical vulnerabilities in a container image in Amazon ECR.

The team used Trivy to identify and fix the issue by updating the base image before redeployment. AWS Config also flagged misconfigured IAM roles, which were resolved by enforcing compliance and implementing least privilege using IAM roles for service accounts (IRSA). This ensured secure and compliant operations for millions of customers.



Industry Relevance

The following tools used in this project serve specific purposes within the industry:

1. **EKS (Amazon Elastic Kubernetes Service):** It manages Kubernetes service by AWS that simplifies running and scaling containerized applications. It integrates with AWS services for security, scalability, and high availability.
2. **GitHub Actions:** It is a CI/CD platform integrated into GitHub that automates development workflows directly from the repository. It supports building, testing, and deploying code based on customizable event triggers, such as a new commit or pull request.
3. **Docker:** It is a containerization platform that enables developers to package applications and their dependencies into portable containers.



Industry Relevance

The following tools used in this project serve specific purposes within the industry:

4. **Trivy:** It offers a platform for source code management and collaboration, seamlessly integrating with CI/CD tools for automated testing and builds, thereby enabling secure and efficient development.
5. **Terraform:** It compiles code, executes tests, and generates build artifacts while incorporating security checks during the CI/CD process, ensuring high-quality builds and supporting safer software delivery.
6. **AWS Security Hub:** AWS Security Hub is a centralized security service that aggregates, organizes, and prioritizes security alerts from various AWS services and third-party tools.



Industry Relevance

The following tools used in this project serve specific purposes within the industry:

4. **Snyk:** It identifies and fixes vulnerabilities in source code, open-source dependencies, containers, and infrastructure as code, integrating with CI/CD pipelines for continuous monitoring and automated remediation.
5. **CloudTrail:** It logs, monitors, and retains account activity related to actions across your AWS infrastructure, providing transparency and supporting compliance with operational policies.
6. **CloudWatch:** AWS CloudWatch collects monitoring and operational data, offering insights through metrics, logs, and alarms to maintain application health and optimize performance.



Tasks

The following tasks outline the process of the secure CI/CD pipeline with automated security monitoring for Kubernetes-hosted applications:

1. Create an EKS cluster with VPC, subnets, and security groups, and enable IAM Roles for Service Accounts (IRSA) for secure AWS service access by Kubernetes workloads
2. Fork the NodeJS repository, set up a GitHub Actions workflow, and configure jobs for building the Docker image, scanning for vulnerabilities, and deploying to EKS
3. Use Docker to build the application container image, push it to Amazon ECR, and integrate Trivy for automated vulnerability scans during image upload
4. Integrate Snyk for SAST, SCA, and penetration scans, securely managing the Snyk auth token with GitHub secrets, and generate actionable reports as GitHub issues



Tasks

The following tasks outline the process of the secure CI/CD pipeline with automated security monitoring for Kubernetes-hosted applications:

5. Automate functional and security tests within the CI/CD pipeline to ensure application reliability and security compliance
6. Implement Pod Security Standards, AWS Security Hub, Amazon Inspector, and CloudTrail for continuous compliance monitoring, and automate alerts and reports



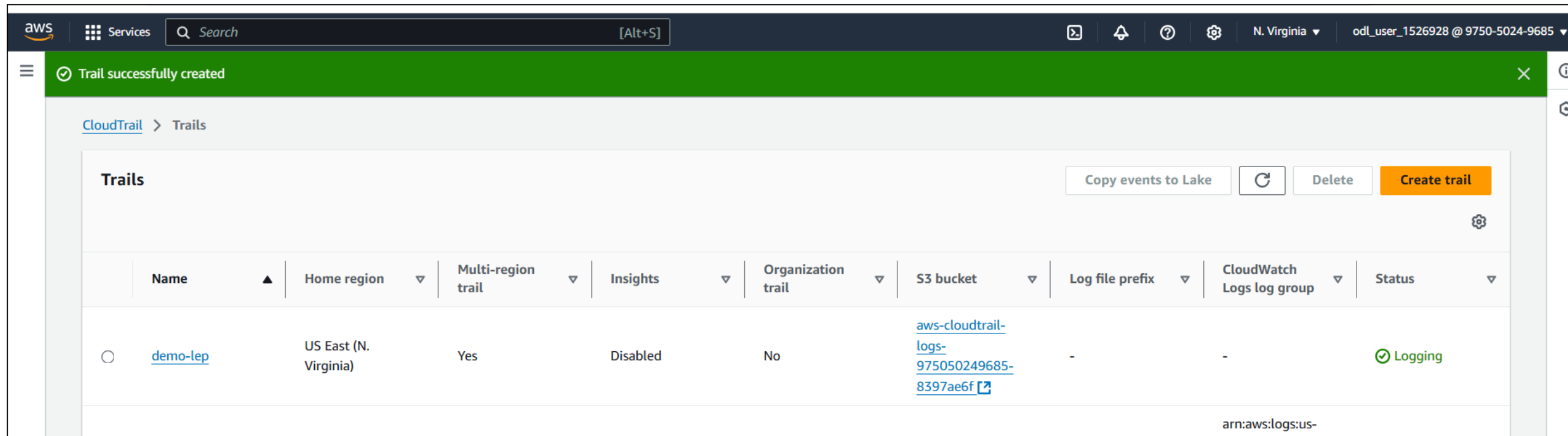
Project References

- **Task 1:** Lesson 03
- **Task 2:** Lesson 03
- **Task 3:** Lesson 01 and Lesson 02
- **Task 4:** Lesson 01
- **Task 5:** Lesson 03
- **Task 6:** Lesson 02 and Lesson 03



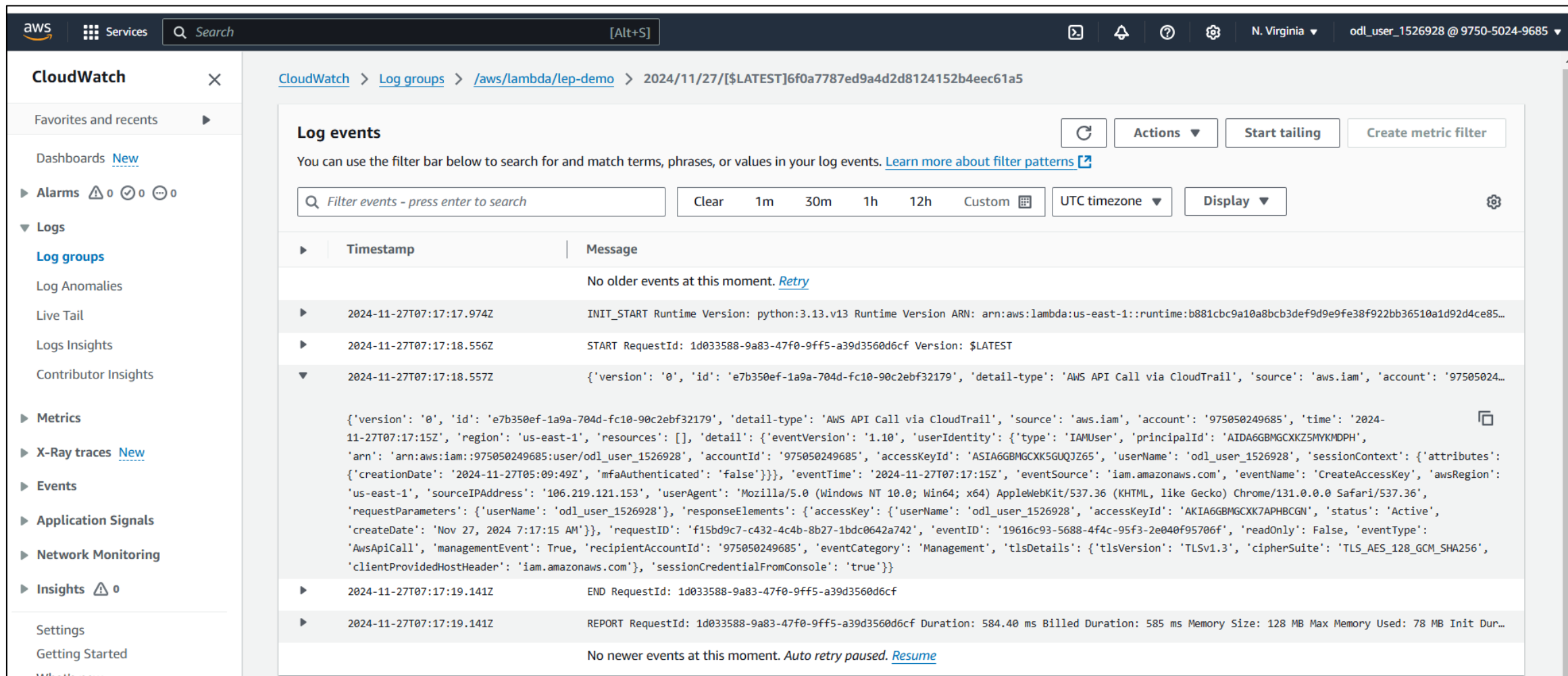
Output Screenshots

DevSecOps pipeline successfully created with integrated security checks to detect vulnerabilities and compliance issues early, as shown below:



Output Screenshots

DevSecOps pipeline successfully created with integrated security checks to detect vulnerabilities and compliance issues early, as shown below:



The screenshot displays the AWS CloudWatch console interface. The left sidebar shows the navigation menu with options like Dashboards, Alarms, Logs, Metrics, X-Ray traces, Events, Application Signals, Network Monitoring, and Insights. The main content area shows the 'Log events' page for a specific log group. The breadcrumb trail indicates the path: CloudWatch > Log groups > /aws/lambda/lep-demo > 2024/11/27/[\$LATEST]6f0a7787ed9a4d2d8124152b4eec61a5. The page includes a search bar, filters for time range (1m, 30m, 1h, 12h, Custom) and display format (UTC timezone, Display). The log events table shows several entries, including an 'INIT_START' event, a 'START' event, and a 'REPORT' event. The 'REPORT' event details show a duration of 584.40 ms, billed duration of 585 ms, memory size of 128 MB, and max memory used of 78 MB.

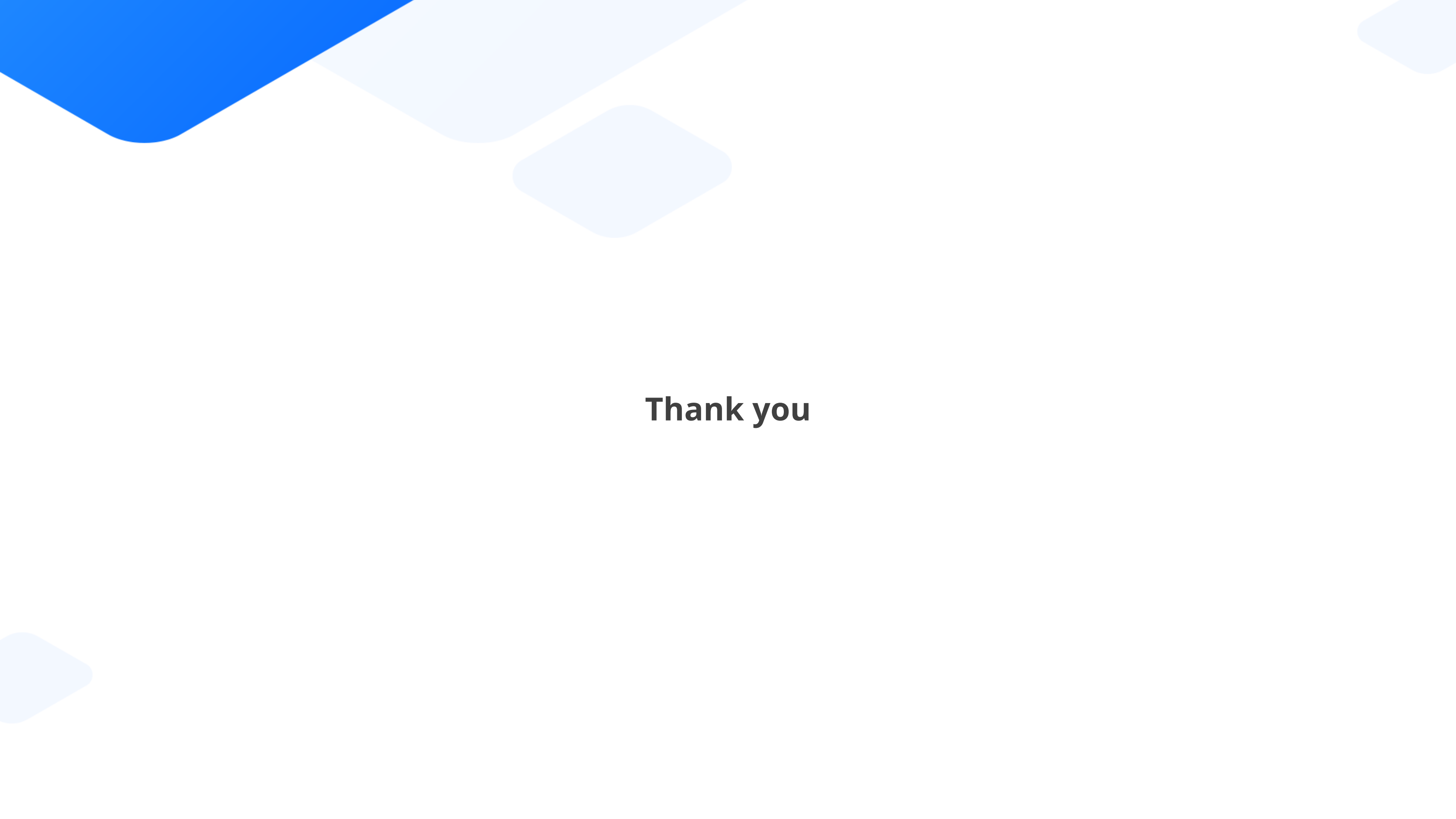
Log events

You can use the filter bar below to search for and match terms, phrases, or values in your log events. [Learn more about filter patterns](#)

Filter events - press enter to search

Clear 1m 30m 1h 12h Custom UTC timezone Display

Timestamp	Message
	No older events at this moment. Retry
2024-11-27T07:17:17.974Z	INIT_START Runtime Version: python:3.13.v13 Runtime Version ARN: arn:aws:lambda:us-east-1::runtime:b881cbc9a10a8bcb3def9d9e9fe38f922bb36510a1d92d4ce85...
2024-11-27T07:17:18.556Z	START RequestId: 1d033588-9a83-47f0-9ff5-a39d3560d6cf Version: \$LATEST
2024-11-27T07:17:18.557Z	{'version': '0', 'id': 'e7b350ef-1a9a-704d-fc10-90c2ebf32179', 'detail-type': 'AWS API Call via CloudTrail', 'source': 'aws.iam', 'account': '97505024...'
	{'version': '0', 'id': 'e7b350ef-1a9a-704d-fc10-90c2ebf32179', 'detail-type': 'AWS API Call via CloudTrail', 'source': 'aws.iam', 'account': '975050249685', 'time': '2024-11-27T07:17:15Z', 'region': 'us-east-1', 'resources': [], 'detail': {'eventVersion': '1.10', 'userIdentity': {'type': 'IAMUser', 'principalId': 'AIDA6GBMGCKXZ5MYKMDPH', 'arn': 'arn:aws:iam::975050249685:user/odl_user_1526928', 'accountId': '975050249685', 'accessKeyId': 'ASIA6GBMGCKX5GUQJZ65', 'userName': 'odl_user_1526928', 'sessionContext': {'attributes': {'creationDate': '2024-11-27T05:09:49Z', 'mfaAuthenticated': 'false'}}}, 'eventTime': '2024-11-27T07:17:15Z', 'eventSource': 'iam.amazonaws.com', 'eventName': 'CreateAccessKey', 'awsRegion': 'us-east-1', 'sourceIPAddress': '106.219.121.153', 'userAgent': 'Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0 Safari/537.36', 'requestParameters': {'userName': 'odl_user_1526928'}, 'responseElements': {'accessKey': {'userName': 'odl_user_1526928', 'accessKeyId': 'AKIA6GBMGCKX7APHBCGN', 'status': 'Active', 'createDate': 'Nov 27, 2024 7:17:15 AM'}}, 'requestID': 'f15bd9c7-c432-4c4b-8b27-1bdc0642a742', 'eventID': '19616c93-5688-4f4c-95f3-2e040f95706f', 'readOnly': False, 'eventType': 'AwsApiCall', 'managementEvent': True, 'recipientAccountId': '975050249685', 'eventCategory': 'Management', 'tlsDetails': {'tlsVersion': 'TLSv1.3', 'cipherSuite': 'TLS_AES_128_GCM_SHA256', 'clientProvidedHostHeader': 'iam.amazonaws.com'}, 'sessionCredentialFromConsole': 'true'}}
2024-11-27T07:17:19.141Z	END RequestId: 1d033588-9a83-47f0-9ff5-a39d3560d6cf
2024-11-27T07:17:19.141Z	REPORT RequestId: 1d033588-9a83-47f0-9ff5-a39d3560d6cf Duration: 584.40 ms Billed Duration: 585 ms Memory Size: 128 MB Max Memory Used: 78 MB Init Dur...
	No newer events at this moment. Auto retry paused. Resume



Thank you